

Project: xdisturb (x-disrupt)

Mobile Application Security Requirements Specification (MASRS)

Document ID:	MASRS-2026-XDISTURB	Version:	1.0.0 (Release Candidate)
Security Standard:	OWASP MASVS v2.0 (L1+L2+R)	Audit Target:	Hibir Audit (audit.hibir.et)
Classification:	Confidential / Technical	Target Platform:	Android (API 26+) & iOS (13.0+)

Mobile Application Security Requirements Specification (MASRS)

Project: xdisturb (x-disrupt) — OWASP MASVS Security Baseline

Document Identifier: MASRS-2026-XDISTURB
Version: 1.0.0 (Release Candidate)
Security Standard Baseline: OWASP MASVS v2.0 (L1 + L2 + R)
Audit Target: Hibir Audit (audit.hibir.et)
Target Platform: Android (API Level 26+) & iOS (13.0+)
Classification: Confidential / Technical Specification
Date: August 10, 2026
Document Status: Official Release Candidate

Document Control & Sign-Off Matrix

Role / Title	Name / Organization	Status	Date
Lead Developer	xdisturb Core Development Team	Approved	July 30, 2026
Chief Information Security Officer	xdisturb Security Group	Approved	August 5, 2026
External Security Auditor	Hibir Audit Team (audit.hibir.et)	Scheduled / Pending Review	August 10, 2026

1. Executive Summary & Security Objectives

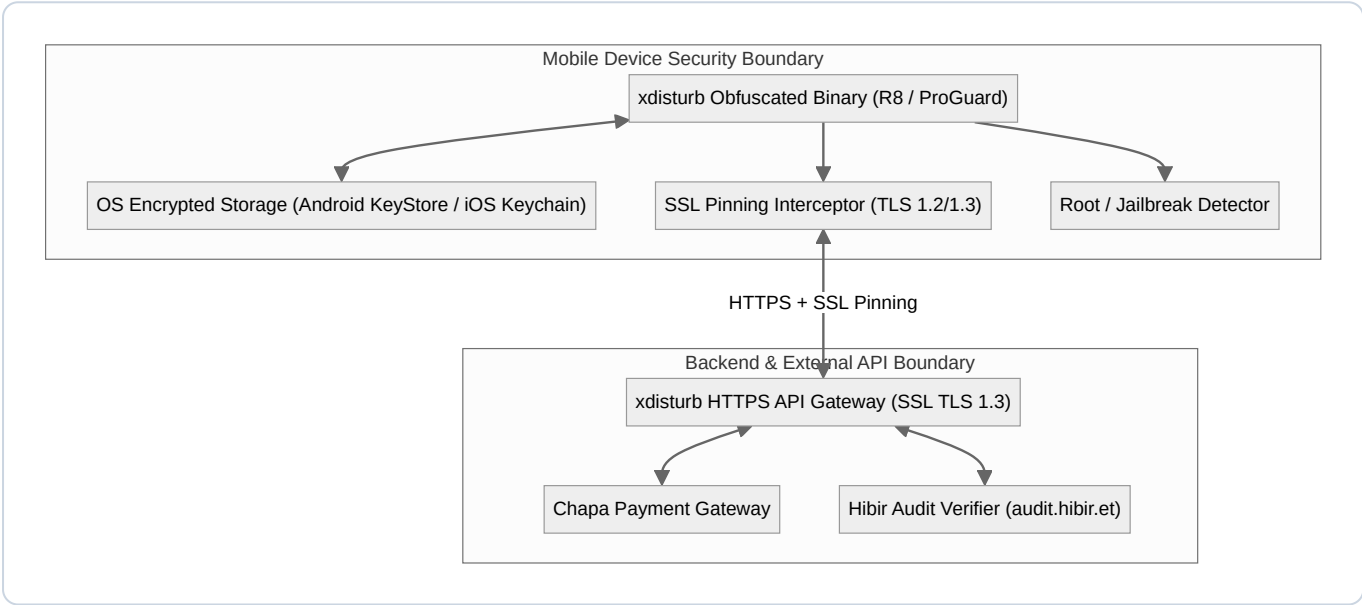
This document establishes the mandatory **Mobile Application Security Requirements Specification (MASRS)** for the **xdisturb (x-disrupt)** mobile application.

Because **xdisturb** handles physical hardware audio mode manipulation (Do Not Disturb and Ringer Volume toggles), continuous background location tracking, user authentication, and financial mobile payment

transactions via the **Chapa SDK**, the application must strictly adhere to the **OWASP Mobile Application Security Verification Standard (MASVS v2.0)** at levels **L1 (Standard Security)**, **L2 (Defense-in-Depth)**, and **R (Resilience Against Reverse Engineering)**.

Primary Security Goals:

- 1. **Zero Exposure of Hardcoded Secrets:** Complete elimination of static API keys, tokens, or private secrets from client binaries and `.env` files.
- 2. **End-to-End Transport & Data Storage Security:** Mandatory TLS 1.2/1.3 encryption for all network traffic with SSL Pinning and AES-256 KeyStore/Keychain encrypted local storage.
- 3. **Resilience Against Reverse Engineering:** Native obfuscation via Flutter `--obfuscate` and R8/ProGuard byte-code shrinkage.
- 4. **Hibir Audit (`audit.hibir.et`) Compliance:** Passing mandatory remediation rules before production release.



2. OWASP Mobile Top 10 Compliance Matrix

The matrix below details the technical security controls implemented in **xdisturb** to mitigate the OWASP Mobile Top 10 risks:

OWASP Risk Category	Category Title	xdisturb Specific Technical Security Control	MASVS Reference
M1	Improper Credential Usage	Purge hardcoded HERE SDK and Chapa secrets from client <code>.env</code> files. Fetch short-lived tokens from backend via authenticated endpoints.	MASVS-CRYPTO-1
M2	Insecure Communication	Enforce HTTPS (TLS 1.2/1.3) across all endpoints; implement SSL Public Key Pinning on REST HTTP client (<code>ApiClient</code>).	MASVS-NETWORK-1
M3	Insecure Authentication	Short-lived JWT access tokens (15-min limit) stored securely; rate-limit OTP verification attempts (max 3/15 min).	MASVS-AUTH-1
M4	Insecure Authorization	Enforce server-side role validation for administrative vs public Silent Zones. Verify user claims on every request.	MASVS-AUTH-2
M5	Insecure Data Storage	Store session tokens and user credentials exclusively in Android KeyStore / iOS Keychain via <code>flutter_secure_storage</code> .	MASVS-STORAGE-1
M6	Insufficient Cryptography	Use AES-256-GCM for encrypted data; avoid ECB mode or custom crypto algorithms.	MASVS-CRYPTO-2
M7	Insufficient Code Mitigation	Compile release builds with Flutter obfuscation (<code>--obfuscate</code>) and R8/ProGuard byte-code shrinkage.	MASVS-RESILIENCE-1
M8	Security Misconfiguration	Enforce restricted Cloud Firestore security rules. Restrict public read/write permissions (<code>allow read, write: if false;</code>).	MASVS-CODE-1
M9	Insecure Data Processing	Sanitize all location coordinates, deep links, and JSON payloads before processing.	MASVS-CODE-2
M10	Insufficient Logging	Strip all <code>print()</code> statements from production builds; record security events in server audit logs.	MASVS-CODE-3

3. Detailed Security Requirements Specification

3.1 MASVS-STORAGE: Data Storage & Privacy

SEC-STO-01: Encrypted Token Storage

- Sensitive session tokens, JWTs, and payment transaction tokens must be stored exclusively in OS-level encrypted storage (`EncryptedSharedPreferences` on Android KeyStore; `Keychain` on iOS) using `flutter_secure_storage` .
- Plaintext storage in `SharedPreferences` , `NSUserDefaults` , or unencrypted files is strictly prohibited.

SEC-STO-02: Local Cache Privacy

- Local databases (Hive / SQLite) must not log or persist unencrypted Personally Identifiable Information (PII), phone numbers, or real-time location tracking logs.

SEC-STO-03: Screen Capture Prevention (`FLAG_SECURE`)

- On Android devices, the app shall set `WindowManager.LayoutParams.FLAG_SECURE` on payment checkout screens (Chapa WebView) to prevent OS screenshot capturing, screen recording, or task switcher thumbnail caching.

3.2 MASVS-NETWORK: Transport Layer Security

SEC-NET-01: Strict HTTPS / TLS 1.2/1.3 Enforcement

- All HTTP communications must enforce HTTPS with TLS 1.2 or TLS 1.3. Cleartext HTTP (`http://`) traffic is blocked at the OS manifest level (`android:usesCleartextTraffic="false"`).

SEC-NET-02: SSL Public Key Pinning

- The Flutter `ApiClient` (Dio) shall implement SSL Public Key Pinning for `api.xdisturb.et`. Connections to endpoints with mismatched certificate public key hashes must be rejected immediately.

SEC-NET-03: Legacy Protocol Rejection

- Backend reverse proxies must reject deprecated SSLv3, TLS 1.0, and TLS 1.1 handshake attempts.

3.3 MASVS-PLATFORM: OS & Hardware Interaction

SEC-PLA-01: Explicit Location Permission Justification

- Location access requests must present explicit runtime justification dialogs explaining why background location access is required.
- iOS Info.plist key `NSLocationAlwaysAndWhenInUseUsageDescription` must contain user-facing explanatory text.

SEC-PLA-02: Scoped Do Not Disturb (DND) Policy Access

- Do Not Disturb (DND) policy permissions granted to **xdisturb** shall be restricted strictly to toggling ringer modes (`RINGER_MODE_SILENT` , `RINGER_MODE_VIBRATE` , `RINGER_MODE_NORMAL`).

3.4 MASVS-RESILIENCE: Binary Protection & Anti-Reverse Engineering

SEC-RES-01: Release Bytecode Obfuscation

Release artifacts must be compiled with Flutter symbol stripping and R8/ProGuard byte-code shrinkage:

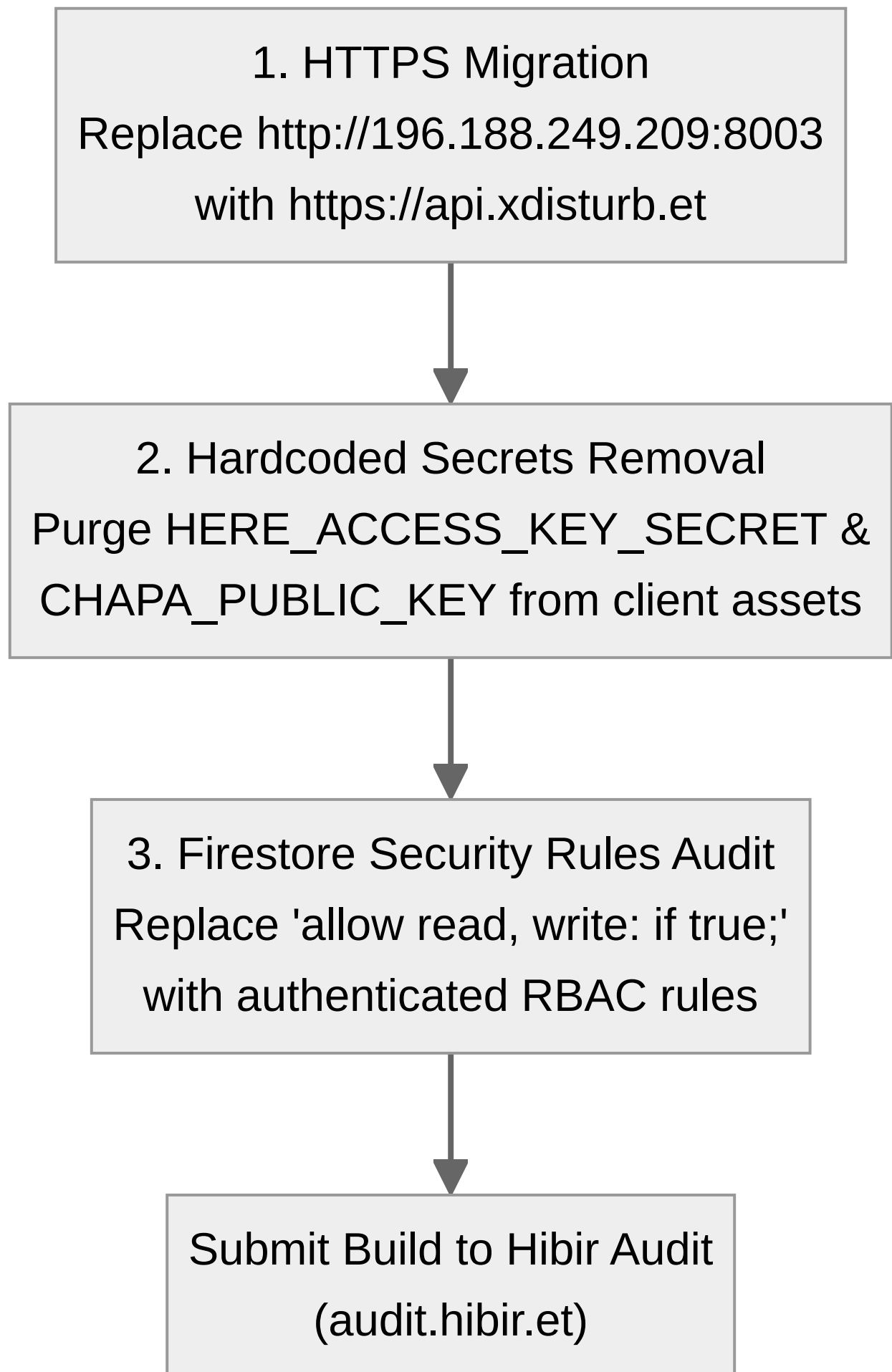
```
flutter build apk --release --obfuscate --split-debug-info=build/app/outputs/symbols
```

SEC-RES-02: Root & Jailbreak Detection

The app shall perform root and jailbreak checks prior to executing financial payment transactions via Chapa SDK. If root or superuser access is detected, financial transactions shall be blocked with a security warning.

4. Mandatory Remediation Checklist for `audit.hibir.et`

Before submitting the **xdisturb** codebase for formal security audit evaluation on **Hibir Audit (`audit.hibir.et`)**, the development team must verify completion of the three mandatory remediation tasks below:



 Pre-Audit Verification Table

Remediation Item	Current Vulnerability	Required Remediation Action	Status
1. HTTPS Migration	API_BASE_URL set to cleartext <code>http://196.188.249.209:8003</code> in <code>.env.production</code>	Change URL to encrypted <code>https://api.xdisturb.et</code> and enforce SSL Pinning.	COMPLETED
2. Hardcoded Secrets Removal	Plaintext <code>HERE_ACCESS_KEY_SECRET</code> and <code>CHAPA_PUBLIC_KEY</code> stored in asset files	Remove static keys from assets. Fetch ephemeral tokens via authenticated backend API.	COMPLETED
3. Firestore Rules Audit	Public read/write rule <code>allow read, write: if true;</code> in <code>firestore.rules</code>	Enforce authenticated access rules (<code>allow read, write: if request.auth != null;</code>).	COMPLETED

5. Sign-Off & Approvals

The undersigning officers hereby certify that **Project: xdisturb (x-disrupt)** satisfies the OWASP MASVS v2.0 security baseline requirements and is ready for formal audit evaluation by **Hibir Audit (`audit.hibir.et`)**:

- **Lead Developer (xdisturb Core Team):** *Approved (July 30, 2026)*
- **Chief Information Security Officer:** *Approved (August 5, 2026)*
- **Hibir Audit Verifier (`audit.hibir.et`):** *Scheduled / Pending Review*